AI Governance Decision Exercise for Applicant Screening

Completed standard exercise using the AI Governance Decision Coach

Decision outcome. Pause for evidence and redesign before any restricted pilot. The proposed system would analyse and filter job applications, directly affecting access to employment. Northstar does not yet have the evidence needed to validate performance, discriminatory impact, transparency, data provenance or effective human oversight.

Boundary. This document is a learning exercise and preliminary governance analysis. It is not legal advice, a compliance certification or final organisational approval. Specialist human review and approval by the accountable recruitment decision owner are required.

Reference date. 1 October 2026. The applicable legal timetable and national requirements should be confirmed before deployment.

1 Scenario summary

Northstar Services is a fictional company operating across several EU countries and receiving about 25,000 applications annually. It proposes a three-month pilot of a vendor system that analyses CVs and application responses, ranks applicants, automatically excludes applicants below a configurable score and generates short score explanations. The proposed roles are customer service, software development and warehouse work.

Recruiters would normally examine only the highest-ranked applicants. Rejected applications would generally be reviewed only after a complaint. The decision is whether Northstar should proceed with the proposed pilot, and under what conditions.

Evidence label	Information and treatment
User-provided information	The proposed workflow, pilot scope, annual application volume and intended recruiter involvement.
Unverified vendor claim	The system is bias tested, 92 percent accurate, GDPR compliant and subject to human oversight.
Assumption	Applicants and deployments are located in the EU; national employment and equality requirements may differ by country.
Missing evidence	Validation and subgroup results, model documentation, data provenance, legal and impact assessments, security evidence, contractual safeguards, monitoring plans and tested oversight procedures.

2 Questions for the user

- Purpose and necessity. Is AI scoring justified, and what less intrusive alternatives could meet the need?
- Affected people. Who benefits, bears risk, may be excluded or may struggle to contest an outcome?
- Data. Are the data sources authorised, relevant, representative, accurate, minimised and appropriately retained?
- Autonomy and oversight. What does the system recommend or decide, and can recruiters meaningfully intervene, override and stop it?
- Possible harms. What discriminatory, economic, privacy, accessibility, security and organisational harms are credible?
- Governance and regulatory exposure. Which policies, standards, legal regimes and accountable roles apply?
- Third parties and reversibility. Can Northstar audit, monitor, suspend, correct, exit and delete data without losing operational continuity?
- Initial decision. Should Northstar approve, approve with conditions, run a restricted pilot, pause, redesign, escalate or reject the proposal?

Learner assessment

The learner concluded that efficiency is a legitimate aim but that Northstar has not demonstrated the necessity or comparative effectiveness of AI scoring. The learner identified structured eligibility checks, skills-based assessment, structured interview rubrics and administrative-only AI as alternatives.

The learner identified affected groups and risks associated with disability, career gaps, non-standard qualifications, minority-language backgrounds and historical patterns. The response also addressed data provenance, representativeness, protected-attribute proxies, automation bias, meaningful oversight, complaints, correction, suspension and exit.

The learner recommended pausing for evidence and redesigning the proposal before permitting a restricted pilot. Suggested pilot safeguards included historical or synthetic data, no automatic rejection, independent human assessment, subgroup testing, candidate transparency and defined monitoring, complaint, override and suspension procedures.

3 Provisional risk assessment

Element	Provisional finding	Reasoning
Inherent risk	High	The system would analyse, rank and potentially exclude applicants from employment opportunities at scale. Errors or bias could create consequential and difficult-to-detect effects.
Control design	Immature	Several safeguards are proposed, but automatic rejection, complaint-triggered review and limited explanations undermine effective oversight and contestability.
Operating evidence	Absent	Northstar has not received the underlying validation, subgroup, provenance, security or oversight evidence. Vendor marketing statements do not demonstrate control operation.
Residual risk	Undetermined	Residual risk cannot be credibly rated until controls are redesigned, tested and evidenced in Northstar's intended context.
Uncertainty	Material	Accuracy definitions, subgroup effects, data rights, model-change practices, national legal requirements and the precise division of provider and deployer duties remain unresolved.

The proposed controls do not reduce the inherent-risk rating merely because they are planned. Northstar should credit a control only after confirming that its design addresses the identified risk and obtaining evidence that it operates effectively. The vendor's 92 percent accuracy statement is not decision-useful until Northstar understands the metric, test population, role-specific results, thresholds and error distribution.

4 Applicable governance considerations

- EU AI Act. AI used to analyse and filter job applications or evaluate candidates is listed as a high-risk employment use case. Northstar should confirm the classification, operator roles and applicable timing with qualified counsel. Current European Commission materials state that Annex III high-risk rules apply from 2 December 2027, while organisations are encouraged to prepare earlier.

- Data protection. Northstar should establish lawful processing, necessity, data minimisation, retention, transparency, data-subject rights, security and whether a data protection impact assessment is required. Counsel and the data protection officer should assess the relevance of GDPR Article 22 and national rules to the actual decision workflow.
- Employment and equality. Legal and equality specialists should test whether the workflow creates direct or indirect discrimination, unreasonable accessibility barriers or inconsistent treatment under the laws of each deployment country.
- Management systems and risk frameworks. ISO IEC 42001 and the NIST AI Risk Management Framework can structure accountability, impact assessment, lifecycle controls, monitoring, documentation and improvement. They do not replace legal analysis or proof that safeguards work.
- Internal governance. Recruitment, privacy, information security, procurement, records-management, accessibility, model-change and incident-management requirements should be mapped to named owners and approval authorities.

5 Required controls

Controls required before any pilot

- Remove automatic rejection. Require an independent recruiter assessment before any adverse screening outcome.
- Define the permitted purpose, job families, input fields, excluded attributes and proxies, decision thresholds and prohibited uses.
- Complete legal, privacy, equality, accessibility, information-security, procurement and AI-governance reviews.
- Obtain role-specific validation, subgroup performance, error analysis, data provenance, model documentation and security evidence.
- Design applicant notices, a meaningful explanation process, accessible alternatives and a timely complaint and correction route.
- Contract for audit rights, change notification, subprocessors, incident support, retention, deletion, data portability, suspension and exit.

Controls required during a restricted pilot

- Use historical or synthetic data first. Do not permit live adverse employment effects until the approval authority accepts the evidence.
- Compare outputs with a predefined non-AI baseline and measure false positive and false negative rates across relevant roles and groups.
- Train recruiters on limitations, automation bias, override expectations and escalation. Monitor whether overrides occur and whether staff can explain them.
- Use stop criteria for unexplained disparities, performance drift, security events, inadequate explanations, unresolved complaints or vendor changes.
- Maintain logs and decision records that support audit, correction and investigation without collecting unnecessary personal data.

Corrective and recovery controls

Northstar should be able to suspend the system immediately, revert to a documented manual process, identify affected applicants, review and correct outcomes, notify appropriate stakeholders, preserve necessary evidence, investigate causes and confirm data deletion or return at exit.

6 Evidence gaps

Missing evidence	Why it matters	Proposed owner
Role-specific validation and subgroup results	Shows whether performance and error rates are acceptable for the actual jobs and affected groups.	Vendor with independent review by Northstar AI governance and equality specialists
Training and evaluation data provenance	Tests authorisation, relevance, representativeness, historical bias and proxy risks.	Vendor, Procurement and Data Protection Officer
System and model documentation	Supports classification, intended-use limits, explanations, change control and technical review.	Vendor and Northstar technology owner
DPIA and legal assessment	Clarifies lawful processing, rights, Article 22 questions and country-specific employment requirements.	Data Protection Officer and Legal
Human oversight procedure and test records	Shows whether recruiters can detect errors, override outputs and avoid rubber-stamping.	Recruitment owner and AI governance lead
Security and incident evidence	Tests access control, logging, resilience, vulnerability handling and breach support.	Information Security and vendor
Contract and exit provisions	Determines whether Northstar can audit, suspend, correct, delete data and maintain continuity.	Procurement, Legal and service owner
Monitoring and complaint metrics	Enables detection of drift, disparities, poor explanations and unresolved applicant harm.	Recruitment owner, AI governance and Data Protection Officer

7 Escalation finding

Specialist human review is mandatory for this exercise because the proposal affects access to employment and contains material uncertainty about discriminatory impact, data rights, model provenance, security, oversight and vendor claims. Required reviewers are Legal, the Data Protection Officer, equality and accessibility specialists, Information Security, Procurement, AI governance and the recruitment process owner.

The accountable business decision owner should be the executive responsible for recruitment or human resources, acting through Northstar's authorised AI governance process. Reviewers advise and set conditions; they do not replace the named owner's accountability. Any risk above the organisation's acceptance threshold should be escalated to the appropriate risk committee or executive authority.

8 Recommended decision

Pause for evidence and redesign before permitting a restricted pilot. Northstar should not approve the proposed live workflow, especially automatic exclusion and complaint-only review. A restricted pilot may proceed only after the pre-pilot controls and evidence requirements are satisfied and approved by the accountable decision owner.

The pilot should begin with historical or synthetic data, use no automatic rejection, preserve independent human assessment, test role-specific and subgroup performance, provide meaningful candidate information and establish tested complaint, correction, override, suspension and manual-fallback procedures. Live use should require a separate approval based on documented results and an explicit residual-risk decision.

9 What the user assessed well

The assessment was strong and proportionate. It did not treat recruitment efficiency as sufficient justification for consequential AI use, and it identified practical alternatives rather than assuming that the only options were deployment or rejection.

- It identified affected groups that may be poorly represented by historical recruitment patterns, including candidates with disabilities, career gaps, non-standard qualifications and minority-language backgrounds.
- It distinguished meaningful oversight from rubber-stamping by requiring understanding, independent assessment, override authority and documented reasoning.
- It connected data provenance and representativeness to discrimination risk instead of treating data quality as a purely technical issue.
- It recognised vendor dependency and proposed auditability, change notification, complaint handling, correction, suspension, fallback and exit controls.
- It selected a defensible decision: pause and redesign now, while preserving a route to a controlled pilot if evidence and safeguards become adequate.

Refinement for the next assessment

The main refinement is to make the control-evidence distinction even more explicit. Proposed safeguards can support a future pilot, but Northstar should not reduce the residual-risk rating until it has verified both control design and operation. It should also define quantitative acceptance and stop criteria before testing begins.

10 Learning points

- Assess inherent risk before crediting controls. Employment screening is consequential because it can shape access to opportunity, even when a human appears somewhere in the workflow.
- A vendor claim is not operating evidence. Accuracy, fairness and compliance statements require definitions, underlying results and validation in the intended context.
- Human involvement is not automatically meaningful oversight. Reviewers need competence, time, information, authority and evidence that they use those capabilities.
- A pilot can harm people. Begin with non-live data where possible, prohibit adverse effects, define stop criteria and require a separate approval before live use.
- Residual risk remains undetermined until safeguards are tested. Material uncertainty can justify a pause even when the anticipated severity is already high.

Reference sources

European Commission, AI Act overview and implementation timeline, Shaping Europe’s Digital Future, accessed 1 October 2026: https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

European Commission, Navigating the AI Act, including examples of employment high-risk systems and provider and deployer duties, accessed 1 October 2026: https://digital-strategy.ec.europa.eu/en/faqs/navigating-ai-act

Regulation EU 2024 1689, consolidated text dated 27 July 2026, EUR-Lex: https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02024R1689-20260727